



Superficie de ataque y exposición organizacional

Temas de esta sección:

- Qué es la superficie de ataque
- Diferencia entre exposición, vulnerabilidad y compromiso
- Superficie externa, interna, humana y cloud/SaaS
- Exposición por terceros y proveedores
- Criticidad del activo: no todo tiene el mismo riesgo
- Cómo priorizar combinando exposición y criticidad
- Errores comunes al analizar superficie de ataque



La superficie de ataque es el conjunto de puntos por los cuales una organización podría ser atacada, accedida, explotada o abusada.

EXTERNA	INTERNA
Sitios web · VPN · Portales de clientes · APIs públicas · Correos corporativos · Repositorios públicos · Dominios y subdominios	Servidores internos · Carpetas compartidas · Controladores de dominio · Cuentas privilegiadas · Redes segmentadas
HUMANA	CLOUD / SaaS
Usuarios que reciben phishing · Admins con permisos elevados · Proveedores externos · Cuentas de ex empleados · Reutilización de contraseñas	M365 · GitHub · Salesforce · AWS/Azure · SharePoint · OneDrive · Apps OAuth de terceros



Tres conceptos relacionados pero distintos que el analista debe saber diferenciar:

EXPOSICIÓN	El activo es accesible o visible desde cierto punto. No implica daño.	<i>Ej: Un servidor está publicado en internet para que los clientes lo usen. Es normal y necesario.</i>
VULNERABILIDAD	El activo tiene una debilidad que podría ser explotada por una amenaza.	<i>Ej: El servidor usa una versión de la aplicación con falla conocida.</i>
COMPROMISO	Existe evidencia de acceso no autorizado, explotación o afectación real.	<i>Ej: Se observó ejecución de comandos en el servidor luego de un request malicioso.</i>

Error frecuente: "Este servidor está expuesto a internet, entonces está comprometido." — Incorrecto. El compromiso requiere evidencia adicional.

2.7 | Priorización: exposición + criticidad del activo



Para priorizar, el analista combina dos preguntas: ¿qué tan expuesto está el activo? + ¿qué tan crítico es para la organización?

Activo	Exposición	Criticidad	Prioridad
Portal de clientes	Internet	Alta	Alta
Controlador de dominio	Interna	Crítica	Alta
Repositorio código productivo	SaaS (GitHub)	Alta	Alta
Notebook de usuario	Remota/VPN	Media	Depende del contexto
Servidor de laboratorio	Interna	Baja	Baja/Media

Esta combinación ayuda a que el SOC no priorice solo por severidad automática de la herramienta.